

2025년 위험관리 계획서

이윤혁 담당자

서홍석 CISO

서일석 대표님

(인)

(인)

(인)

1. 위험관리 대상

- 인프라(서버, 네트워크, 정보보호 솔루션, DBMS)
- MA/MBP 웹/앱 서비스
- 정보보호 관치체계

2. 취약점 분석 및 영향도 산정 방법

- 서버 등 인프라 자산 : 기준선 접근법
 - 영향도 : 자산 중요도 + 취약점 등급
 - 상 = 9 이상, 중 = 8 이하 ~ 5이상, 하 = 5 이하
- 웹/앱 서비스 : 기준선 접근법
 - 영향도 : 서비스 중요도 + 취약점 등급
 - 상 = 9 이상, 중 = 8 이하 ~ 5이상, 하 = 5 이하
- 정보보호 관리체계 : 복합적 접근법
 - 영향도 : 법적 준거성 + 취약점 등급
 - 상 = 6 이상, 중 = 5 이하 ~ 4이상, 하 = 3 이하

3. 위험평가 및 위험도 산정 방법

- 위험도 = 영향도(상/중/하) + 침해(장애) 발생가능성(고/저) + 비용 및 소요시간(저/중/고)
- DOA (수용 가능한 위험 수준) : 위험도 5 이하 수용

4. 위험 관리 방안

- 1) 위험감소(Mitigation): 위험을 감소시킬 수 있는 대책을 마련하여 구현
- 2) 위험회피(Avoidance): 위험이 존재하는 자산을 제거
- 3) 위험수용(Acceptance): 위험을 받아들이고 잠재적 손실 비용을 감수
- 4) 위험전가(Transfer): 보험이나 외주 등으로 잠재적 비용을 제3자에게 이전

5. 위험 관리 계획

5.1 인프라(서버, 네트워크, 정보보호 솔루션, DBMS)

- 서버

평가_ID	항목	대상 서버	위험도	조치 일정	위험 관리
SRV-005	SMTP 서비스의 expn/vrfy 명령어 실행 제한 미비	- console-ma-service - core-ecs-node - mbp-ecs-node	7	10월 30일	감소
SRV-006	SMTP 서비스 로그 수준 설정 미흡	- console-ma-service - core-ecs-node - mbp-ecs-node	7	10월 30일	감소
SRV-007	취약한 버전의 SMTP 서비스 사용	- console-ma-service - core-ecs-node - mbp-ecs-node"	7	10월 30일	감소
SRV-009	SMTP 서비스 스팸 메일 릴레이 제한 미설정	- console-ma-service - core-ecs-node - mbp-ecs-node	7	10월 30일	감소
SRV-010	SMTP 서비스의 메일 queue 처리 권한 설정 미흡	- console-ma-service - core-ecs-node - mbp-ecs-node	7	10월 30일	감소
SRV-026	root 계정 원격 접속 제한 미비	- console-core-ma - operation - console-ma-service - core-ecs-node - mbp-ecs-node - moin-prd-dbsafer - moin-prd-ips	8	10월 30일	감소
SRV-069	비밀번호 관리정책 설정 미비	- KR-IDC-PROXY-1 - KR-IDC-PROXY-2	8	10월 30일	감소
SRV-087	C 컴파일러 존재 및 권한 설정 미흡	- moin-prd-dbsafer	7	10월 30일	감소
SRV-091	불필요하게 SUID, SGID bit가 설정된 파일 존재	- console-core-ma-operation - console-ma-service - core-ecs-node - mbp-ecs-node - moin-prd-dbsafer - moin-prd-ips - KR-IDC-PROXY-1 - KR-IDC-PROXY-2	7	10월 30일	감소
SRV-095	존재하지 않는 소유자 및 그룹 권한을 가진 파일 또는 디렉터리 존재	- moin-prd-dbsafer	8	10월 30일	감소
SRV-096	사용자 환경파일의 소유자 또는 권한 설정 미흡	- console-core-ma-operation - console-ma-service - core-ecs-node - mbp-ecs-node - moin-prd-dbsafer	9	10월 30일	감소

		- moin-prd-ips - KR-IDC-PROXY-1 - KR-IDC-PROXY-2			
SRV-109	시스템 주요 이벤트 로그 설정 미흡	- console-core-ma-operation	9	10월 30일	감소
SRV-112	Cron 서비스 로깅 미설정	- console-core-ma-operation	9	10월 30일	감소
SRV-115	로그의 정기적 검토 및 보고 미수행	- console-core-ma-operation - console-ma-service - core-ecs-node - mbp-ecs-node - moin-prd-dbsafer - moin-prd-ips - KR-IDC-PROXY-1 - KR-IDC-PROXY-2	9	10월 30일	감소
SRV-122	UMASK 설정 미흡	- console-ma-service - core-ecs-node - mbp-ecs-node - moin-prd-dbsafer - moin-prd-ips	8	10월 30일	감소
SRV-127	계정 잠금 임계값 설정 미비	- KR-IDC-PROXY-1 - KR-IDC-PROXY-2	8	10월 30일	감소
SRV-163	시스템 사용 주의사항 미출력	- console-core-ma-operation - console-ma-service - core-ecs-node - mbp-ecs-node - moin-prd-dbsafer - moin-prd-ips - KR-IDC-PROXY-1 - KR-IDC-PROXY-2	9	10월 30일	감소
SRV-164	구성원이 존재하지 않는 GID 존재	- KR-IDC-PROXY-1 - KR-IDC-PROXY-2	9	10월 30일	감소
SRV-170	SMTP 서비스 정보 노출	- core-ecs-node - mbp-ecs-node - moin-prd-dbsafer	9	10월 30일	감소
SRV-175	NTP 및 시각 동기화 미설정	- KR-IDC-PROXY-1 - KR-IDC-PROXY-2	9	10월 30일	감소

- 네트워크

평가_ID	항목	대상 서버	위험도	조치 일정	위험 관리
NET-001	네트워크 장비 설정 백업 여부	- T5004	5	10월30일	감소
NET-001	네트워크 장비 설정 백업 여부	- Ring AX - A - Ring AX - B - Ring AX 4F back - Ring AX 4F front	4	10월30일	감소
NET-013	원격 관리 접근 통제	- T5004 - Ring AX - A - Ring AX - B - Ring AX 4F back - Ring AX 4F front	6	10월30일	감소
NET-015	VTY 접속 시 안전하지 않은 프로토콜(TELNET 등) 사용	- T5004	5	10월30일	감소
NET-015	VTY 접속 시 안전하지 않은 프로토콜(TELNET 등) 사용	- Ring AX - A - Ring AX - B - Ring AX 4F back - Ring AX 4F front	4	10월30일	감소
NET-031	NTP 설정 및 시각 동기화 여부	- T5004 - Ring AX - A - Ring AX - B - Ring AX 4F back - Ring AX 4F front	5	10월30일	감소
NET-036	원격 로그서버 연동 설정	- T5004 - Ring AX - A - Ring AX - B - Ring AX 4F back - Ring AX 4F front	5	12월 30일	감소
NET-048	최신/긴급 보안 패치 및 업데이트 적용 여부	- T5004 - Ring AX - A - Ring AX - B - Ring AX 4F back - Ring AX 4F front	6	10월30일	감소

- 정보보안 시스템

평가_ID	항목	대상 서버	위험도	조치 일정	위험 관리
ISS-001	보안장비 정책 및 로그 백업 설정	평촌 - FG-80F 평촌 - AX-80D	7	10월 30일	감소
ISS-002	원격 로그 서버 사용	평촌 - FG-80F 평촌 - AX-80 Dmoin-prd-ips	7	10월 30일	감소
ISS-006	보안장비 사용량의 주기적인 점검 및 보고	평촌 - FG-80F 평촌 - AX-80D querypie	7	10월 30일	감소
ISS-007	보안장비 장애/보안이벤트 모니터링 실시	평촌 - FG-80F 평촌 - AX-80D querypie	7	10월 30일	감소
ISS-008	탐지된 이벤트 및 로그에 대한 정기적 분석 및 보고	평촌 - FG-80F 평촌 - AX-80D querypie	7	10월 30일	감소
ISS-010	TCP/UDP/ICMP 탐지/차단 패턴 적용 여부	moin-prd-ips	7	10월 30일	감소
ISS-011	Port Scan 탐지/차단 패턴 적용	moin-prd-ips	7	10월 30일	감소
ISS-012	해킹 툴 탐지/차단 패턴 적용	moin-prd-ips	8	10월 30일	감소
ISS-019	보안장비 계정 관리	HQ Firewall	8	10월 30일	감소
ISS-021	보안장비 원격 관리 접근 통제	평촌 - AX-80D querypie moin-prd-ips1	8	10월 30일	감소
ISS-023	로그인 실패횟수 제한	평촌 - AX-80D	8	10월 30일	감소
ISS-024	세션 타임아웃 설정	평촌 - AX-80D	8	10월 30일	감소
ISS-025	NTP 설정 및 시각 동기화	평촌 - AX-80D	7	10월 30일	감소
ISS-028	보안장비 정책 변경통제 절차 수립	평촌 - FG-80F 평촌 - AX-80D HQ Firewall	7	10월 30일	감소
ISS-029	보안장비 변경요청 정책의 기술적 검토	평촌 - FG-80F 평촌 - AX-80D HQ Firewall	7	10월 30일	감소
ISS-030	모든 목적지 및 서비스로의 허용 오류	평촌 - FG-80F 평촌 - AX-80D HQ Firewall	8	12월 30일	감소
ISS-031	취약한 서비스의 네트워크 대역 단위 허용	평촌 - FG-80F 평촌 - AX-80D HQ Firewall	8	12월 30일	감소

ISS-032	과도한 서비스 포트 허용	평촌 - FG-80F 평촌 - AX-80D HQ Firewall	8	12월 30일	감소
ISS-033	불필요한 양방향 정책 허용	평촌 - FG-80F 평촌 - AX-80D HQ Firewall	8	10월 30일	감소
ISS-036	취약한 원격서비스 허용	평촌 - FG-80F 평촌 - AX-80D HQ Firewall	8	10월 30일	감소
ISS-037	기타 불필요한 정책 적용	평촌 - FG-80F	4	10월 30일	감소
ISS-040	보안장비 비밀번호의 주기적인 변경	평촌 - FG-80F 촌 - AX-80D HQ Firewall moin-prd-ips	7	10월 30일	감소
ISS-041	불필요한 네트워크 대역 단위 허용	평촌 - FG-80F	8	10월 30일	감소

- DBMS

평가_ID	항목	대상 서버	위험도	조치 일정	위험 관리
DBM-008	주기적인 비밀번호 변경 미흡	core-v2023-04-12-001 mbp-v2023-08-03-001	5	10월30일	감소
DBM-009	사용되지 않는 세션 종료 미흡	core-v2023-04-12-001 mbp-v2023-08-03-001	5	10월30일	감소

5.2 MA/MBP 웹/앱 위험 관리 계획

평가_ID	항목	대상 서비스	위험도	조치 일정	위험 관리
WEB-SER-002	악성파일 업로드	- 모인 WEB	9	10월 30일	감소
WEB-SER-006 MOB-SER-006	유추가능한 인증정보 이용	- 모인 WEB - 모인 비즈 WEB	9	10월 30일	감소
WEB-SER-011 MOB-SER-011	외부사이트에 의한 시스템 운영 정보 노출 여부	- 모인 WEB	9	10월 30일	감소
WEB-SER-032 MOB-SER-032	인증 오류 횟수 제한기능 제공 여부	- 모인 WEB	9	10월 30일	감소
WEB-SER-033 MOB-SER-033	불충분한 세션종료 처리	- 모인 WEB	9	10월 30일	감소
WEB-SER-040 MOB-SER-040	불필요한 파일 노출 여부	- 모인 AOS	9	10월 30일	감소
MOB-SER-043	백그라운드 화면 보호	- 모인 AOS - 모인 IOS	9	10월 30일	감소
WEB-SER-048 MOB-SER-048	세션정보 재사용	- 모인 WEB	9	10월 30일	감소
WEB-SER-049 MOB-SER-049	인증수단 소유자 검증 여부	- 모인 WEB	9	10월 30일	감소
WEB-SER-051 MOB-SER-051	통신구간 암호화 적용 여부	- 모인 WEB	9	10월 30일	감소

5.3 관리체계 위험 관리 계획

평가_ID	평가항목	위험도	조치 일정	위험 관리
FISM-016	정보보안점검의 날 지정 여부	8	10월 30일	감소
FISM-017	정보보안 점검의 날 금융감독원장이 정한 정보보호 점검항목에 대한 점검 이행(매월) 여부	7	10월 30일	감소
FISM-018	정보보안 점검의 날 점검결과에 관한 최고경영자에게 보고 여부	8	10월 30일	감소
FISM-061	사용자 단말기에서 보조기억매체 및 휴대용 전산장비에 관한 접근통제 (정보유출, 악성코드 감염방지 등) 여부	8	10월 30일	감소
FISM-064	전산자료 및 전산장비의 반출/반입 통제 여부	8	10월 30일	감소
FISM-065	보조기억매체 등 전산자료에 대한 안전지출 및 파기계획 수립 및 운용 여부	8	10월 30일	감소
FISM-066	보조기억매체 보유현황 및 관리실태에 관한 정기점검 및 책임자 확인 여부	7	10월 30일	감소
FISM-067	전산자료의 정기백업/소산 등 백업내역에 관한 기록 및 관리 여부	7	10월 30일	감소
FISM-069	주요 백업 전산자료에 대한 정기 검증 여부	7	10월 30일	감소
FISM-070	이용자 정보 조회 및 출력에 대한 통제 여부	8	12월 31일	감소
FISM-072	정보처리시스템 가동기록(정보처리시스템 접속기록, 전산자료 사용기록, 전산자료 처리기록) 1년 이상 보존 여부	7	12월 31일	감소
FISM-079	주요 정보처리시스템에 대한 시스템 운영 매뉴얼에 구동, 조작방법, 명령어사용법, 운용순서, 장애조치 및 연락처 등 포함 여부	7	10월 30일	감소
FISM-080	주요 프로그램에 대한 유지보수 관리대장에 작업일, 작업내용, 작업결과 등을 작성 및 보관 여부	7	10월 30일	감소
FISM-081	데이터베이스관리시스템(Database Management System : DBMS), 운영체제(Operating System), 웹프로그램에 대한 주기적 유지보수 여부	8	10월 30일	감소
FISM-083	정상작동여부 확인을 위한 정보처리시스템 자원 상태의 감시, 경고 및 제어가 가능한 모니터링 시스템 설치 및 운영 여부	6	12월 31일	감소
FISM-086	운영체제, 시스템 유틸리티 등의 긴급하고 중요한 보정(patch)사항에 대하여는 즉시 보정 여부	7	12월 31일	감소
FISM-087	중요도에 따른 운영체제(Operating System) 및 설정내용 등의 정기 백업, 원격안전지역 소산 및 백업자료 1년 이상 기록/관리 여부	7	12월 31일	감소
FISM-091	정보처리시스템 사용 현황 및 추이 분석 등 정기적 실시 여부	7	10월 30일	감소
FISM-097	내부 단말기의 정보보호시스템을 우회한 인터넷 등 외부 통신망(무선 통신망 포함) 접속 차단 여부	8	10월 30일	감소
FISM-099	내부통신망에서의 파일 배포기능 이용 시 파일 무결성 검증 수행 여부	7	12월 31일	감소
FISM-101	정보보호시스템에 최소한의 서비스번호와 기능 적용 여부	8	10월 30일	감소

FISM-103	정보보안 정책 승인 및 적용 시, 정책 등록, 변경, 삭제 내용에 대한 보관 여부	7	10월 30일	감소
FISM-106	정보보호시스템 작동상태 모니터링 여부	7	10월 30일	감소
FISM-107	정보보호시스템에 대한 백업 및 복구절차 수립 및 시행 여부	7	10월 30일	감소
FISM-109	무선통신망 이용 업무의 정보보호최고책임자 승인 및 사전 지정 여부	7	10월 30일	감소
FISM-110	사용자인증, 암호화 등 무선통신망 보안대책 수립	8	10월 30일	감소
FISM-111	금융회사 내부망에 연결된 정보처리시스템이 지정 된 업무 용도와 사용 지역(zone) 이외의 무선통신망에 접속하는 것을 차단하기 위한 차단시스템 구축 여부	8	10월 30일	감소
FISM-112	무선통신망 실시간 모니터링체계 운영 여부	7	10월 30일	감소
FISM-113	비인가 무선접속장비 설치/접속여부 및 중요정보노출여부에 대한 주기적 점검 여부	7	10월 30일	감소
FISM-116	악성코드 감염대비 복구절차 마련 여부	7	10월 30일	감소
FISM-117	중요 단말기의 악성코드 감염 여부 매일 점검 여부	8	10월 30일	감소
FISM-126	공개용 웹서버 게시자료에 대한 사전 관리 실시 여부	7	10월 30일	감소
FISM-127	공개용 웹서버에 무기명 또는 가명에 의한 게시 금지 여부	7	10월 30일	감소
FISM-131	단말기에서 음란, 도박 등 업무와 무관한 프로그램 및 인터넷사이트에 대한 접근 통제 여부	8	10월 30일	감소
FISM-134	개인별로 내부 IP주소를 부여 및 유지/관리 여부	7	10월 30일	감소
FISM-135	내/외부 IP주소의 인터넷 접속내용 1년이상 별도 기록/보관 여부	7	10월 30일	감소
FISM-139	암호프로그램의 비담당자 이용에 관한 통제 여부	7	12월 31일	감소
FISM-143	개인별 사용자계정 및 비밀번호 부여 여부	8	10월 30일	감소
FISM-144	외부사용자에 대한 최소 작업권한 할당 및 통제장치 설치 여부	8	10월 30일	감소
FISM-146	사용자 인사조치 시 지체없이 해당 사용자 계정 삭제, 사용 중지, 공동 사용 계정 변경 등 정보처리시스템 접근 통제 여부	8	10월 30일	감소
FISM-147	사용자 계정 공동사용 시 개인별 사용내역에 대한 기록저장 및 관리 여부	7	10월 30일	감소
FISM-170	전산원장 변경절차에 변경 대상 및 방법 포함 여부	8	10월 30일	감소
FISM-171	전산원장 변경절차에 변경 권한자 지정 포함 여부	7	10월 30일	감소
FISM-172	전산원장 변경 절차에 변경 전후 내용 자동기록 및 보존 포함 여부	8	10월 30일	감소
FISM-173	저사원장 변경절차에 변경내용이 정당한지에 대한 제3자 확인 포함 여부	8	10월 30일	감소

